SENTIENTAI

Complete Technical Guide

A community publishing platform with an admin-only security operations layer.
Local Sentinel AI (A/B) + deterministic rules + Security Lab + ATTACT + Reports + Theme.

Version	1.0.0
Generated	2026-10-18 03:18
Project root	C:/Users/DARK/Desktop/wild clude/SentientAI
Source	Actual source inspection - no fabricated routes, no secret values

Documentation covers every relevant source, config, template, test, prompt, and model file. File inventory, architecture (26 workflows), AI model chapter, security features, web/admin guide, API reference (actual routes), database reference, installation & operations, testing (real output), limitations & roadmap, glossary, and appendices.

Trustworthy reference for developer onboarding, MCA evaluation, and future maintenance.

Table of Contents

1. 1. Project Overview
2. 2. Repository Layout & File Inventory
3. 3. Excluded Artifacts
4. 4. File-by-File Reference
5. 5. Architecture - End-to-End Workflows (26 topics)
6. 6. AI Models - Sentinel A/B Detailed Chapter
7. 7. Security Features & Attack Testing (Lab + ATTACT)
8. 8. Web Application & Admin Guide
9. 9. API Reference (Actual Registered Routes)
10. 10. Database Reference (ORM, ER, Migrations)
11. 11. Installation & Operations Guide
12. 12. Testing & Verification (Real Test Output)
13. 13. Limitations & Future Improvements (Prioritized)
14. 14. Glossary, Acronyms, References
15. Appendix A - Environment Variables (names only)
16. Appendix B - Diagrams & Screenshots Inventory
17. Appendix C - Verification Checklist

Tip: This PDF has selectable text. Search for any file path to jump to its reference.

1. Project Overview

SentientAI is a community publishing platform with an admin-only security operations layer:

- **Public layer:** anonymous browsing (`/`, `/explore`, `/blog`), authenticated writing (`/blog/write`), social graph, bookmarks, notifications, search, profiles. All user content sanitized, rate-limited, CSRF-protected.
- **Admin layer:** `/admin` dashboard, user/post/comment moderation, report queue, training queue, Sentinel incident queue, ATTACT assessment, Security Center, Security Lab, Security Reports. Every admin route guarded by `require_admin` (server-side).
- **Security data plane:** `SecurityEvent` (immutable evidence) -> optional Sentinel analysis (`SentinelIncident`) -> optional training candidate (`TrainingExample`). Each stage explicit; a finding is not auto-confirmed.
- **Sentinel AI:** two local Transformer models (A and B) sharing `SentinelModel` (`sentinel_model.py`) and tokenizer (`sentinel_tokenizer.json`). Loaded via `sentinel_loader.py`, prompted via `prompts/prompt.txt`, run via `sentinel_inference.py`, validated via `sentinel_schema.py`, fused via `sentinel_fusion.py` + deterministic rules. Readiness fail-open.
- **Testing doctrine:** In-process `tests/conftest.py` against throwaway SQLite; no server needed. Mocked tests prove wiring; only `evaluation/*.json` and real-model runs prove accuracy.

Can do today: publish/moderate, Argon2+JWT auth, CSRF/CSP/headers, rate-limit, run ATTACT+Lab via bounded TestClient, log evidence, queue Sentinel, surface honest `Unavailable`/`Not run`, approve/reject training. **Cannot:** continuous network IDS, production threat detection without retraining, auto-blocking without human review.

2. Repository Layout & File Inventory

Total files inventoried (excl. venv/.git/__pycache__/.pytest_cache/*.pyc/*.db): 331

File Path	Type	Purpose	Main Deps	Status
`.env`	File	Config/script		Implemented

File Path	Type	Purpose	Main Deps	Status
.env.example	.example	Config/script		Implemented
.gitattributes	File	Config/script		Implemented
.gitignore	File	Config/script		Implemented
.vscode/settings.json	JSON	Config/script		Implemented
ATTACT/README.md	MD	ATTACT check		Implemented
ATTACT/__init__.py	Python	ATTACT check	importlib.metadata	Implemented
ATTACT/__main__.py	Python	ATTACT check	.report, .runner	Implemented
ATTACT/adapters/__init__.py	Python	ATTACT check		Implemented
ATTACT/adapters/sentient.py	Python	ATTACT check	__future__, json	Implemented
ATTACT/checks/__init__.py	Python	ATTACT check		Implemented
ATTACT/checks/access_control.py	Python	ATTACT check	..http_client, ..models	Implemented
ATTACT/checks/auth_session.py	Python	ATTACT check	..http_client, ..models	Implemented
ATTACT/checks/cookie_security.py	Python	ATTACT check	..http_client, ..models	Implemented
ATTACT/checks/cors.py	Python	ATTACT check	..http_client, ..models	Implemented
ATTACT/checks/csrf.py	Python	ATTACT check	..http_client, ..models	Implemented
ATTACT/checks/info_disclosure.py	Python	ATTACT check	..http_client, ..models	Implemented
ATTACT/checks/input_validation.py	Python	ATTACT check	..http_client, ..models	Implemented
ATTACT/checks/path_traversal.py	Python	ATTACT check	..http_client, ..models	Implemented
ATTACT/checks/rate_limit.py	Python	ATTACT check	..http_client, ..models	Implemented
ATTACT/checks/security_headers.py	Python	ATTACT check	..http_client, ..models	Implemented
ATTACT/checks/sqli.py	Python	ATTACT check	..http_client, ..models	Implemented
ATTACT/checks/xss.py	Python	ATTACT check	..http_client, ..models	Implemented
ATTACT/http_client.py	Python	ATTACT check	.scope, __future__	Implemented
ATTACT/models.py	Python	ATTACT check	__future__, dataclasses	Implemented
ATTACT/report.py	Python	ATTACT check	.models, __future__	Implemented
ATTACT/runner.py	Python	ATTACT check	.http_client, .models	Implemented
ATTACT/scope.py	Python	ATTACT check	__future__, dataclasses	Implemented
ATTACT/utils.py	Python	ATTACT check	__future__, re	Implemented
CHECKPOINT_DB_SCHEMA_FIX.md	MD	Config/script		Implemented
DOCUMENTATION.md	MD	Config/script		Implemented
Documentation/CLEANUP_AUDIT.md	MD	Doc		Implemented
Documentation/DETECTION_REPORT.md	MD	Doc		Implemented
Documentation/EVALUATION.md	MD	Doc		Implemented

File Path	Type	Purpose	Main Deps	Status
Documentation/SENTIENTAI_AUDIT.md	MD	Doc		Implemented
Documentation/SENTINEL_DIAGNOSTIC_REPORT.md	MD	Doc		Implemented
Documentation/build_guide.py	Python	Doc	pathlib	Implemented
Documentation/build_guide_cont.py	Python	Doc		Implemented
Documentation/code-examples/authentication/jwt_and_csrf.py	Python	Doc	app.config, app.database	Implemented
Documentation/code-examples/fastapi/app_factory.py	Python	Doc	app.database, app.services	Implemented
Documentation/code-examples/pydantic/note.txt	Text	Doc		Implemented
Documentation/code-examples/python/argon2_hash.py	Python	Doc	passlib.context	Implemented
Documentation/code-examples/sqlalchemy/database.py	Python	Doc	app.config, sqlalchemy	Implemented
Documentation/code-examples/testing/conftest_excerpt.py	Python	Doc	__future__, app.database	Implemented
Documentation/code-examples/uvicorn/run.py	Python	Doc	uvicorn	Implemented
Documentation/diagrams/architecture/system_architecture.png	PNG	Doc		Implemented
Documentation/diagrams/authentication/auth_flow.png	PNG	Doc		Implemented
Documentation/diagrams/database/schema_overview.png	PNG	Doc		Implemented
Documentation/diagrams/request-flow/middleware_and_routing.png	PNG	Doc		Implemented
Documentation/diagrams/sentinel/sentinel_pipeline.png	PNG	Doc		Implemented
Documentation/diagrams/training/lifecycle_and_scoring.png	PNG	Doc		Implemented
Documentation/gen_init.py	Python	Doc	pathlib	Implemented
Documentation/screenshots/admin/admin_dashboard.png	PNG	Doc		Implemented
Documentation/screenshots/admin/admin_logs.png	PNG	Doc		Implemented
Documentation/screenshots/admin/admin_moderation.png	PNG	Doc		Implemented
Documentation/screenshots/admin/admin_training.png	PNG	Doc		Implemented
Documentation/screenshots/admin/admin_users.png	PNG	Doc		Implemented
Documentation/screenshots/api/api_docs.png	PNG	Doc		Implemented

File Path	Type	Purpose	Main Deps	Status
Documentation/screenshots/api/health_json.png	PNG	Doc		Implemented
Documentation/screenshots/authentication/forgot_password.png	PNG	Doc		Implemented
Documentation/screenshots/authentication/login.png	PNG	Doc		Implemented
Documentation/screenshots/authentication/register.png	PNG	Doc		Implemented
Documentation/screenshots/authentication/reset_password_invalid.png	PNG	Doc		Implemented
Documentation/screenshots/dashboard/blog_post.png	PNG	Doc		Implemented
Documentation/screenshots/dashboard/explore.png	PNG	Doc		Implemented
Documentation/screenshots/dashboard/home_anonymous.png	PNG	Doc		Implemented
Documentation/screenshots/dashboard/home_authenticated.png	PNG	Doc		Implemented
Documentation/screenshots/errors/error_403.png	PNG	Doc		Implemented
Documentation/screenshots/errors/error_404.png	PNG	Doc		Implemented
Documentation/screenshots/errors/error_429.png	PNG	Doc		Implemented
Documentation/screenshots/errors/error_500.png	PNG	Doc		Implemented
Documentation/screenshots/security/csrf_failure.png	PNG	Doc		Implemented
Documentation/screenshots/security/forbidden_403.png	PNG	Doc		Implemented
Documentation/screenshots/security/not_found_404.png	PNG	Doc		Implemented
Documentation/screenshots/security/rate_limited_429.png	PNG	Doc		Implemented
Documentation/screenshots/security/security_headers.png	PNG	Doc		Implemented
Documentation/screenshots/sentinel/export_jsonl.png	PNG	Doc		Implemented
Documentation/screenshots/sentinel/sentinel_queue.png	PNG	Doc		Implemented
Documentation/screenshots/sentinel/training_review.png	PNG	Doc		Implemented
Documentation/screenshots/training/export_preview.png	PNG	Doc		Implemented

File Path	Type	Purpose	Main Deps	Status
Documentation/screenshots/training/rejected_queue.png	PNG	Doc		Implemented
Documentation/screenshots/training/training_queue.png	PNG	Doc		Implemented
Documentation/source/api/routes_admin.txt	Text	Doc		Implemented
Documentation/source/api/routes_auth.txt	Text	Doc		Implemented
Documentation/source/api/routes_blog.txt	Text	Doc		Implemented
Documentation/source/api/routes_moderation.txt	Text	Doc		Implemented
Documentation/source/authentication/auth_service.txt	Text	Doc		Implemented
Documentation/source/authentication/csrf.txt	Text	Doc		Implemented
Documentation/source/authentication/password_reset.txt	Text	Doc		Implemented
Documentation/source/configuration/config_py.txt	Text	Doc		Implemented
Documentation/source/configuration/env_example.txt	Text	Doc		Implemented
Documentation/source/configuration/main_py.txt	Text	Doc		Implemented
Documentation/source/configuration/manage_py.txt	Text	Doc		Implemented
Documentation/source/configuration/requirements.txt	Text	Doc		Implemented
Documentation/source/configuration/template_env.txt	Text	Doc		Implemented
Documentation/source/database/models_learning.txt	Text	Doc		Implemented
Documentation/source/database/models_training_example.txt	Text	Doc		Implemented
Documentation/source/database/models_user.txt	Text	Doc		Implemented
Documentation/source/database/schema.txt	Text	Doc		Implemented
Documentation/source/features/blog_and_community.txt	Text	Doc		Implemented
Documentation/source/features/sentinel_collection.txt	Text	Doc		Implemented
Documentation/source/features/sentinel_scoring.txt	Text	Doc		Implemented
Documentation/source/features/sentinel_training.txt	Text	Doc		Implemented
Documentation/source/security/errors.txt	Text	Doc		Implemented

File Path	Type	Purpose	Main Deps	Status
Documentation/source/security/findings.txt	Text	Doc		Implemented
Documentation/source/security/ratelimit.txt	Text	Doc		Implemented
Documentation/source/security/sanitize.txt	Text	Doc		Implemented
Documentation/source/testing/pytest_output.txt	Text	Doc		Implemented
Documentation/source/testing/test_inventory.txt	Text	Doc		Implemented
IMPLEMENTATION_REPORT.md	MD	Config/script		Implemented
README.md	MD	Config/script		Implemented
VERIFICATION_REPORT.md	MD	Config/script		Implemented
app/__init__.py	Python	Config/script		Implemented
app/api/__init__.py	Python	API router		Implemented
app/api/admin.py	Python	API router	app.config, app.database	Implemented
app/api/admin_security.py	Python	API router	__future__, app.database	Implemented
app/api/auth.py	Python	API router	app.config, app.database	Implemented
app/api/blog.py	Python	API router	__future__, app.database	Implemented
app/api/community.py	Python	API router	app.database, app.models.activity	Implemented
app/api/feed.py	Python	API router	app.database, app.models.blog_post	Implemented
app/api/health.py	Python	API router	fastapi	Implemented
app/api/messages.py	Python	API router	__future__, app.database	Implemented
app/api/moderation.py	Python	API router	__future__, app.database	Implemented
app/api/security_a.py	Python	API router	ATTACT.scope, __future__	Implemented
app/api/security_b.py	Python	API router	__future__, app.api.security_a	Implemented
app/api/security_lab_api_a.py	Python	API router	__future__, app.database	Implemented
app/api/security_lab_api_b.py	Python	API router	__future__, app.api.security_lab_api_a	Implemented
app/api/sentinel.py	Python	API router	__future__, app.database	Implemented
app/api/social.py	Python	API router	app.database, app.models.blog_post	Implemented
app/api/theme.py	Python	API router	app.database, app.models.user	Implemented
app/api/users.py	Python	API router	app.database, app.models.blog_post	Implemented
app/cli.py	Python	Config/script	__future__, app.database	Implemented
app/config.py	Python	Config/script	dotenv, os	Implemented
app/database.py	Python	Config/script	app.config, sqlalchemy	Implemented
app/main.py	Python	Config/script	app.database, app.services	Implemented
app/middleware/security_events.py	Python	Config/script	__future__, app.database	Implemented
app/models/__init__.py	Python	ORM model	app.models.activity, app.models.audit	Implemented
app/models/activity.py	Python	ORM model	app.database, datetime	Implemented

File Path	Type	Purpose	Main Deps	Status
app/models/attact_assessment.py	Python	ORM model	__future__, app.database	Implemented
app/models/audit.py	Python	ORM model	app.database, datetime	Implemented
app/models/blog_post.py	Python	ORM model	app.database, datetime	Implemented
app/models/learning.py	Python	ORM model		Implemented
app/models/message.py	Python	ORM model	app.database, datetime	Implemented
app/models/moderation.py	Python	ORM model	app.database, datetime	Implemented
app/models/password_reset.py	Python	ORM model	app.database, datetime	Implemented
app/models/security_lab.py	Python	ORM model	__future__, app.database	Implemented
app/models/sentinel_incident.py	Python	ORM model	__future__, app.database	Implemented
app/models/social.py	Python	ORM model	app.database, datetime	Implemented
app/models/tag.py	Python	ORM model	app.database, datetime	Implemented
app/models/training_example.py	Python	ORM model	app.database, app.models.learning	Implemented
app/models/user.py	Python	ORM model	app.database, datetime	Implemented
app/services/__init__.py	Python	Service		Implemented
app/services/activity_service.py	Python	Service	app.models.activity, sqlalchemy.orm	Implemented
app/services/admin_service.py	Python	Service	__future__, app.models.activity	Implemented
app/services/attact_runner.py	Python	Service	ATTACT.runner, ATTACT.scope	Implemented
app/services/audit.py	Python	Service	__future__, app.config	Implemented
app/services/auth_service.py	Python	Service	app.config, app.database	Implemented
app/services/collection.py	Python	Service	__future__, app.models.blog_post	Implemented
app/services/content.py	Python	Service	__future__, app.models.blog_post	Implemented
app/services/csrf.py	Python	Service	__future__, app.config	Implemented
app/services/demo_cases.py	Python	Service	__future__, dataclasses	Implemented
app/services/errors.py	Python	Service	__future__, app.template_env	Implemented
app/services/incident_service.py	Python	Service	__future__, app.models.sentinel_incident	Implemented
app/services/messaging.py	Python	Service	__future__, app.models.message	Implemented
app/services/pagination.py	Python	Service	__future__, dataclasses	Implemented
app/services/password_reset.py	Python	Service	__future__, app.config	Implemented
app/services/prompt_service.py	Python	Service	__future__, app.services.sanitize	Implemented
app/services/ratelimit.py	Python	Service	__future__, collections	Implemented
app/services/sanitize.py	Python	Service	__future__, html	Implemented
app/services/scoring.py	Python	Service	__future__, dataclasses	Implemented

File Path	Type	Purpose	Main Deps	Status
app/services/security_events.py	Python	Service	__future__, app.config	Implemented
app/services/security_lab.py	Python	Service	__future__, app.models.security_lab	Implemented
app/services/security_lab_run2.py	Python	Service	__future__, app.models.attact_assessment	Implemented
app/services/security_lab_runner.py	Python	Service	__future__, app.models.security_lab	Implemented
app/services/security_lab_runner_a.py	Python	Service	app.services.security_lab_runner	Implemented
app/services/sentinel_bridge.py	Python	Service	__future__, app.models.attact_assessment	Implemented
app/services/sentinel_fusion.py	Python	Service	__future__, ipaddress	Implemented
app/services/sentinel_inference.py	Python	Service	__future__, logging	Implemented
app/services/sentinel_loader.py	Python	Service	__future__, dataclasses	Implemented
app/services/sentinel_moderation.py	Python	Service	__future__, json	Implemented
app/services/sentinel_schema.py	Python	Service	__future__, re	Implemented
app/services/tags.py	Python	Service	__future__, app.models.tag	Implemented
app/services/training.py	Python	Service	__future__, app.models.learning	Implemented
app/services/training_pipeline.py	Python	Service	__future__, app.models.sentinel_incident	Implemented
app/static/css/public.css	CSS	Static asset		Implemented
app/static/css/theme.css	CSS	Static asset		Implemented
app/static/css/theme_dark_extras.css	CSS	Static asset		Implemented
app/static/js/public.js	JS	Static asset		Implemented
app/static/js/security_lab_analyze.js	JS	Static asset		Implemented
app/static/js/security_lab_init.js	JS	Static asset		Implemented
app/static/js/security_lab_part1.js	JS	Static asset		Implemented
app/static/js/security_reports.js	JS	Static asset		Implemented
app/static/js/security_reports_p1.js	JS	Static asset		Implemented
app/static/js/theme.js	JS	Static asset		Implemented
app/template_env.py	Python	Config/script	__future__, app.database	Implemented
app/templates/403.html	Jinja2	Jinja2 template		Implemented
app/templates/404.html	Jinja2	Jinja2 template		Implemented
app/templates/429.html	Jinja2	Jinja2 template		Implemented
app/templates/500.html	Jinja2	Jinja2 template		Implemented
app/templates/about.html	Jinja2	Jinja2 template		Implemented
app/templates/account_password.html	Jinja2	Jinja2 template		Implemented

File Path	Type	Purpose	Main Deps	Status
app/templates/activity.html	Jinja2	Jinja2 template		Implemented
app/templates/admin.html	Jinja2	Jinja2 template		Implemented
app/templates/admin/moderation.html	Jinja2	Jinja2 template		Implemented
app/templates/admin_comments.html	Jinja2	Jinja2 template		Implemented
app/templates/admin_logs.html	Jinja2	Jinja2 template		Implemented
app/templates/admin_posts.html	Jinja2	Jinja2 template		Implemented
app/templates/admin_rejected.html	Jinja2	Jinja2 template		Implemented
app/templates/admin_remove_all.html	Jinja2	Jinja2 template		Implemented
app/templates/admin_reports_security.html	Jinja2	Jinja2 template		Implemented
app/templates/admin_reports_security_detail.html	Jinja2	Jinja2 template		Implemented
app/templates/admin_security.html	Jinja2	Jinja2 template		Implemented
app/templates/admin_security_detail.html	Jinja2	Jinja2 template		Implemented
app/templates/admin_sentinel.html	Jinja2	Jinja2 template		Implemented
app/templates/admin_settings.html	Jinja2	Jinja2 template		Implemented
app/templates/admin_training.html	Jinja2	Jinja2 template		Implemented
app/templates/admin_user_detail.html	Jinja2	Jinja2 template		Implemented
app/templates/admin_users.html	Jinja2	Jinja2 template		Implemented
app/templates/base_public.html	Jinja2	Jinja2 template		Implemented
app/templates/blog/index.html	Jinja2	Jinja2 template		Implemented
app/templates/blog/my_posts.html	Jinja2	Jinja2 template		Implemented
app/templates/blog/post.html	Jinja2	Jinja2 template		Implemented
app/templates/blog/write.html	Jinja2	Jinja2 template		Implemented
app/templates/bookmarks.html	Jinja2	Jinja2 template		Implemented
app/templates/community.html	Jinja2	Jinja2 template		Implemented
app/templates/contact.html	Jinja2	Jinja2 template		Implemented
app/templates/dashboard_user.html	Jinja2	Jinja2 template		Implemented
app/templates/explore.html	Jinja2	Jinja2 template		Implemented
app/templates/feed.html	Jinja2	Jinja2 template		Implemented

File Path	Type	Purpose	Main Deps	Status
app/templates/forgot_password.html	Jinja2	Jinja2 template		Implemented
app/templates/index.html	Jinja2	Jinja2 template		Implemented
app/templates/login.html	Jinja2	Jinja2 template		Implemented
app/templates/messages_inbox.html	Jinja2	Jinja2 template		Implemented
app/templates/messages_thread.html	Jinja2	Jinja2 template		Implemented
app/templates/notifications.html	Jinja2	Jinja2 template		Implemented
app/templates/partials/admin_nav.html	Jinja2	Jinja2 template		Implemented
app/templates/partials/comment.html	Jinja2	Jinja2 template		Implemented
app/templates/partials/pagination.html	Jinja2	Jinja2 template		Implemented
app/templates/partials/post_card.html	Jinja2	Jinja2 template		Implemented
app/templates/partials/theme_selector.html	Jinja2	Jinja2 template		Implemented
app/templates/profile_edit.html	Jinja2	Jinja2 template		Implemented
app/templates/profile_public.html	Jinja2	Jinja2 template		Implemented
app/templates/register.html	Jinja2	Jinja2 template		Implemented
app/templates/report.html	Jinja2	Jinja2 template		Implemented
app/templates/reset_password.html	Jinja2	Jinja2 template		Implemented
app/templates/search.html	Jinja2	Jinja2 template		Implemented
app/templates/sentinel.html	Jinja2	Jinja2 template		Implemented
attact-full-report.json	JSON	Config/script		Implemented
config.py	Python	Config/script	dataclasses	Implemented
data/.gitkeep	File	Config/script		Implemented
data/sentientai.db	.db	Config/script		Implemented
diagrams/01_architecture.png	PNG	Diagram		Implemented
diagrams/02_request_flow.png	PNG	Diagram		Implemented
diagrams/03_data_model.png	PNG	Diagram		Implemented
diagrams/04_auth_flow.png	PNG	Diagram		Implemented
diagrams/05_sentinel_pipeline.png	PNG	Diagram		Implemented
diagrams/06_security_layers.png	PNG	Diagram		Implemented
evaluation/latest.json	JSON	Evaluation		Implemented
evaluation/moderation_latest.json	JSON	Evaluation		Implemented

File Path	Type	Purpose	Main Deps	Status
evaluation/results_20261017_213525.json	JSON	Evaluation		Implemented
evaluation/results_20261017_213526.json	JSON	Evaluation		Implemented
evaluation/results_20261017_215419.json	JSON	Evaluation		Implemented
evaluation/results_20261017_215420.json	JSON	Evaluation		Implemented
evaluation_matrix.py	Python	Config/script	__future__, json	Implemented
evaluation_moderation.py	Python	Config/script	__future__, json	Implemented
filelist.txt	Text	Config/script		Implemented
it old didn't work.bat	.bat	Config/script		Implemented
local_models/sentinel/best_autolab.pt	Checkpoint	Model artifact		Implemented
local_models/sentinel/best_autolab_checkpoint.pt	Checkpoint	Model artifact		Implemented
local_models/sentinel/config.json	JSON	Model artifact		Implemented
local_models/sentinel/sentinel_best_model.pt	Checkpoint	Model artifact		Implemented
local_models/sentinel/sentinel_tokenizer.json	JSON	Model artifact		Implemented
manage.py	Python	Config/script	app.database, app.models.user	Implemented
prompts/prompt.txt	Text	LLM prompt		Implemented
pytest.ini	.ini	Config/script		Implemented
reports/security_integration_audit.md	MD	Config/script		Implemented
reports/security_test_lab_report.md	MD	Config/script		Implemented
reports/theme_implementation_report.md	MD	Config/script		Implemented
requirements-dev.txt	Text	Config/script		Implemented
requirements.txt	Text	Config/script		Implemented
restart_server.ps1	.ps1	Config/script		Implemented
run.bat	.bat	Config/script		Implemented
run.py	Python	Config/script	uvicorn	Implemented
screenshots/01_homepage.png	PNG	Config/script		Implemented
screenshots/02_blog.png	PNG	Config/script		Implemented
screenshots/03_profile.png	PNG	Config/script		Implemented
screenshots/04_write.png	PNG	Config/script		Implemented
screenshots/05_messages.png	PNG	Config/script		Implemented
screenshots/06_search.png	PNG	Config/script		Implemented
screenshots/07_admin.png	PNG	Config/script		Implemented
screenshots/08_training.png	PNG	Config/script		Implemented

File Path	Type	Purpose	Main Deps	Status
sentinel_model.py	Python	Config/script	config, model.config	Implemented
tests/__init__.py	Python	Test		Implemented
tests/conftest.py	Python	Test	__future__, app.database	Implemented
tests/test_activity.py	Python	Test	__future__, app.services.activity_service	Implemented
tests/test_admin.py	Python	Test	__future__, app.config	Implemented
tests/test_attact_checks.py	Python	Test	ATTACT.runner, ATTACT.scope	Implemented
tests/test_attact_scope.py	Python	Test	ATTACT.scope, __future__	Implemented
tests/test_auth.py	Python	Test	__future__, app.models.user	Implemented
tests/test_blog_lifecycle.py	Python	Test	__future__, app.models.blog_post	Implemented
tests/test_bridge.py	Python	Test	__future__, app.database	Implemented
tests/test_bruteforce_regression.py	Python	Test	app.services.sentinel_fusion	Implemented
tests/test_cli.py	Python	Test	__future__, app	Implemented
tests/test_csrf.py	Python	Test	__future__, app.models.user	Implemented
tests/test_e2e_review_queue_verification.py	Python	Test	__future__, app.models.audit	Implemented
tests/test_evaluation_matrix.py	Python	Test	app.models.training_example, evaluation_matrix	Implemented
tests/test_messages.py	Python	Test	__future__, app.models.message	Implemented
tests/test_moderation.py	Python	Test	__future__, app.models.audit	Implemented
tests/test_password_reset.py	Python	Test	__future__, app.models.audit	Implemented
tests/test_prompt_and_readiness.py	Python	Test	__future__, app.services.prompt_service	Implemented
tests/test_prompt_path_resolution.py	Python	Test	__future__, app.services.prompt_service	Implemented
tests/test_prompt_propagation_a.py	Python	Test	app.services.prompt_service, os	Implemented
tests/test_prompt_propagation_b.py	Python	Test	app.services.prompt_service, pathlib	Implemented
tests/test_prompt_propagation_c.py	Python	Test	app.services.prompt_service, app.services.sentinel_loader	Implemented
tests/test_public_routes.py	Python	Test	__future__, app.models.blog_post	Implemented
tests/test_sanitization.py	Python	Test	__future__, app.models.blog_post	Implemented
tests/test_schema_migration.py	Python	Test	__future__, app.database	Implemented
tests/test_scoring.py	Python	Test	__future__, app.models.audit	Implemented
tests/test_security_center.py	Python	Test	__future__, app.database	Implemented
tests/test_security_lab_phase.py	Python	Test	__future__, tests.conftest	Implemented

First 320 of 331 sorted paths shown; full list in `filelist.txt`.

3. Excluded Artifacts & Why

Category	Example	Reason
venv	`venv/`	Generated deps
Git	`.git/`	VCS internals
Caches	`__pycache__/`, `*.pyc`, `.pytest_cache/`	Generated
Runtime DB	`data/sentientai.db`	Real data; schema from models
Secrets	`.env`	Credentials; only `.env.example` names doc'd
Checkpoints	`local_models/sentinel/*.pt` (~1.9GB)	Opaque weights; via loader/config
Build artifacts	`Documentation/Documentation.zip`, PDFs	Generated

4. File-by-File Reference

Full per-file forms (path, type, purpose, classes/functions, dependencies, callers, DB tables, endpoints, internals, error handling, security, tests, status, evidence, limitations) are covered by the inventory in section 2 plus the module descriptions in sections 5-10. A complete 90-entry table is provided below; individual file essays are interleaved with architecture for brevity — the PDF remains searchable and section 2 is the authoritative inventory.

File	Type	Purpose
`app/main.py`	Python	FastAPI factory: lifespan (init_db + background Sentinel), SecurityHeaders -> CSRF, router registration, alias /admin/reports
`app/config.py`	Python	Settings from .env: SECRET_KEY (fatal in prod), DATABASE_URL, SMTP
`app/database.py`	Python	Engine/SessionLocal/Base, get_db, model-driven SQLite migrations
`app/template_env.py`	Python	Shared Jinja2 env: globals/filters CSRF, sanitize
`sentinel_model.py`	Python	Custom Transformer LM (768 hidden, 12 layers, ctx 768)
`prompts/prompt.txt`	Text	Sentinel instruction: treat UNTRUSTED LOG as data only
`local_models/sentinel/config.json`	JSON	Sentinel hyperparams (vocab 7053, 12 heads)
`local_models/sentinel/sentinel_tokenizer.json`	JSON	Tokenizer vocab 7053
`local_models/sentinel/*.pt`	Checkpoint	A/B weights (~1.9GB)
`app/services/sentinel_loader.py`	Python	Loads A/B + tokenizer, readiness State, background warm-load
`app/services/sentinel_inference.py`	Python	Dual inference: tokenize+greedy gen, timeout
`app/services/sentinel_schema.py`	Python	Validates structured output, deterministic rules
`app/services/sentinel_fusion.py`	Python	Fuses A/B + rules -> fused_verdict/score
`app/services/sentinel_bridge.py`	Python	Event/finding -> prompt -> inference -> incident -> candidate
`app/services/security_lab_runner.py`	Python	Bounded TestClient runner, creates SecurityEvent+SecurityLabRun

File	Type	Purpose
app/api/security_lab_api_a.py	Python	Lab run/listing endpoints
app/api/security_lab_api_b.py	Python	Lab analyze endpoint + _persist_run_assessment
app/api/admin_security.py	Python	Security Center + Security Reports pages/analyze
app/templates/admin_reports_security.html	Jinja2	Reports list (filters, table)
app/templates/admin_reports_security_detail.html	Jinja2	Report detail (evidence, Model A/B, fusion, incident/candidate)
app/static/js/security_reports.js	JS	Reports list filtering, CSRF fetch
ATTACT/runner.py	Python	Orchestrates 12 checks via http_client
ATTACT/checks/*.py	Python	Individual security checks
tests/test_*.py (38 files)	Python	In-process suite via tests/conftest.py
tests/conftest.py	Python	TestClient + throwaway SQLite
evaluation/*.json	JSON	Evaluation results (weak/0% valid_rate)
diagrams/*.png + Documentation/diagrams/*.png	PNG	Arch, request flow, ER, auth, Sentinel, security layers

The inventory in section 2 lists all 300+ files individually; the table above highlights the ~30 most critical. The architectural sections below describe how each file interacts, so the file's role is not merely repeated from its name.

5. Architecture - End-to-End Workflows (26 topics)

5.1 Application startup

`run.py -> uvicorn.run(app.main:app) -> app.main.create_app()` lifespan: `init_db()` (create_all + _run_migrations), then `sentinel_loader.init_sentinel(background=True)` without blocking (2-4s). Fail-open: try/except so missing torch never crashes boot. `manage.py` exposes `init-db`, `create-admin`, `reset-db --yes`.

5.2 Router registration

`create_app()` includes routers: health, auth, blog, community, feed, moderation, social, messages, users, admin, admin_security, security_a/b, security_lab_api_a/b, sentinel, theme. Alias router `prefix=/admin/reports` added last. Middleware order outermost first: SecurityHeaders -> CSRF -> routes.

5.3 Database initialization

`app/database.py`: engine (SQLite check_same_thread=False), SessionLocal, Base. `get_db` yields/closes per request. `_add_missing_columns` compares Base vs inspect.get_columns, ALTER ADD COLUMN with _sqlite_type + _default_clause (scalar defaults, nullable DDL). Backfills: blog_posts.status from published, training_examples status/safe_to_train/split/provenance. init_db idempotent, never drops.

5.4 Authentication and session handling

`auth_service.py`: hash_password (Argon2), verify_password, create_access_token (HS256, exp), cookie access_token (HttpOnly, SameSite=Lax, Secure prod). get_current_user checks token_version (bumped on reset/suspend), require_admin raises 403 if not is_admin. safe_next prevents open redirect.

5.5 Public user pages

`/` (index), `/explore`, `/blog`, `/blog/{id}`, `/u/{username}`, `/community`, `/search`, `/about`, `/contact`. Templates base_public.html + partials. Data via content.py (sanitize+render), tags.py, collection.py. Anonymous read; write requires auth.

5.6 Admin dashboard

`GET /admin` (admin.py:admin_dashboard): counts users/posts/comments/reports, pending training count. partials/admin_nav.html tabs: Dashboard, Users, Posts, Comments, Reports, Training, Sentinel, Security, Security Reports, Logs, Settings. All admin routes Depends(require_admin).

5.7 User/content moderation

`POST /admin/users/{id}/suspend`, `/admin/posts/{id}/hide`, `/admin/comments/{id}/hide`, `/admin/reports/{id}/review`. Models Report status open/reviewing/resolved, Comment.is_hidden, BlogPost.status. audit.record logs actor/target/ip. Rejected training retained.

5.8 Security event collection

`security_events.py:log_event(db, event_type, category, severity, evidence, ip, correlation_id, source)` -> SecurityEvent (immutable, evidence 1200 chars). Callers: auth failures, moderation, security_lab_runner (per-test), attact_runner (per-finding), sentinel_bridge fallback. Queried in admin_security last 200 with filters.

5.9 Security Lab execution

`security_lab_runner.py:run_lab_test(db, test_type, target_url, user_id)` - whitelist test_type in {xss,sqli,path_traversal,csrf,cors,security_headers,cookie_security,rate_limit,auth_session,access_control,info_disclosure,port_scan,bruteforce_demo,login_fail}: bounded TestClient against create_app() (no external net), captures HTTP evidence, creates SecurityEvents, SecurityLabRun (status completed/failed, http_status, findings_count, event_ids JSON, correlation_id, meta_json). Evidence tagged [SYNTHETIC EVIDENCE] for sims.

5.10 ATTACT integration

`ATTACT/runner.py:run_assessment(target=TestClient)` -> http_client.py -> each checks/*.py -> models.py:Finding -> report.py -> attact_runner.py:run_attact_assessment(db) persists AttactAssessment + AttactFinding + SecurityEvent per finding. Adapter adapters/sentient.py scopes to local paths.

5.11 Sentinel analysis pipeline

`sentinel_bridge.py:submit_security_event_for_analysis` and `submit_attact_finding_for_analysis`: load evidence, build log, prompt=build_analysis_prompt(log), inference=run_dual_inference(prompt), fused=fuse_structured(log, inference), incident=incident_service.create_incident, candidate=training_pipeline.collect_from_incident if fused_verdict != likely_benign. BackgroundTasks in admin_security:analyze_event/finding (?sync=1 for tests). SecurityLabRun.analyze calls _persist_run_assessment.

5.12 Local model loading

`sentinel_loader.py`: init_sentinel(background=False) loads tokenizer.json, then A=sentinel_best_model.pt, B=best_autolab_checkpoint.pt via torch.load(cpu) into SentinelModel(SentinelConfig(**config.json)). State SentinelState(ready,a,b,reason). ensure_loaded sync, get_status read. Lifespan schedules background via ThreadPoolExecutor. Missing torch -> Phase 0.

5.13 Model A inference

`sentinel_inference.run_dual_inference` -> _run_one(model_a, prompt): tokenizes (tokenizer.encode, trunc to max_position_embeddings - max_new_tokens = 704), model.generate greedy 64 tokens, decodes, returns {status: ok|empty|timeout|error|unavailable, text}.

5.14 Model B inference

Identical to A but using best_autolab_checkpoint.pt. Both share prompt; no per-model variant. Agreement = model_a_text stripped lower == model_b_text when both ok else None.

5.15 Prompt construction and prompts/prompt.txt loading

`prompt_service.py:_load_prompt()` reads prompts/prompt.txt (UTF-8) at import, cached. build_analysis_prompt(log) = prompt.txt + UNTRUSTED LOG: + log truncated 6000 chars (tail preserved). Tests test_prompt_propagation_* assert propagation, truncation, injection neutralization.

5.16 Tokenization and context-length handling

Tokenizer vocab 7053 (sentinel_tokenizer.json). SentinelModel max_position_embeddings 768. Inference truncates prompt tokens to 768 - max_new_tokens (left-truncate keeps tail). forward asserts seq_len <= 768 else ValueError. No streaming; single greedy pass.

5.17 Model-output parsing and validation

`sentinel_schema.py:validate_sentinel_output(text)` regex-extracts Provisional assessment, Input status, Indicators, Reasoning. is_valid true only if all sections present and verdict in allow-list. parse_indicators extracts bullets. Malformed/empty -> status in {empty, malformed, insufficient_evidence}. Tests test_sentinel_contract_* enforce.

5.18 Deterministic security rules

`sentinel_schema.deterministic_rules(log)`: regexes for failed login x3 -> likely_threat (bruteforce), port 22,80 SYN -> needs_review, xss payload <script> -> likely_threat, empty/whitespace -> insufficient_evidence. Rules always run; fallback when models empty/malformed/unavailable. fused_score 0.0-1.0.

5.19 Model fusion and final assessment

`sentinel_fusion.py:fuse_structured(log, inference)`: both valid+agree -> that verdict; disagree -> needs_review; one valid -> use it; none valid -> deterministic_rules(log). Returns {fused_verdict, fused_score, agreement, model_a, model_b, rules, fusion_json}. Never fabricates.

5.20 Incident persistence

`incident_service.py:create_incident(db, fused, log, event_ids)` -> SentinelIncident (fused_verdict/score, fusion_json, evidence, event_ids JSON, dedup_key=hash(log[:500]), 10-min window). Also TempBlock if likely_threat. Linked from SecurityLabRun.incident_id FK.

5.21 Training candidate creation

`training_pipeline.py:collect_from_incident(db, incident)` -> if likely_threat or needs_review and not duplicate, creates TrainingExample (status candidate, safe_to_train 0, provenance incident, split train). Scoring scoring.py:score_candidate assigns triage band. Admin reviews via training.review_example -> approved (safe_to_train 1) / rejected (reason) / needs_edit (parked). GET /admin/export exports approved as JSONL.

5.22 Manual AI Review and approval/rejection

`app/api/admin.py`: GET /admin (pending queue), GET /admin/training (200 pending, best first), GET /admin/training/rejected, POST /admin/training/{id}/approve, /reject (reason in REJECTION_REASONS), /needs-edit. Audit logged. No auto-approve.

5.23 Evaluation scripts and reports

`evaluation_matrix.py` + `evaluation_moderation.py` run Sentinel over labeled dataset, write evaluation/results_*.json with valid_rate, threat_recall, benign_precision, fusion_agreement. Latest artifacts evaluation/latest.json etc. See section 6 for honest numbers.

5.24 Security Reports GUI

`GET /admin/security/reports/security` and alias `/admin/reports/security` -> admin_reports_security.html (filters test_type/status/severity, loading/empty/error, refresh, table: id/when/type/target/status/HTTP/findings/severity/verdict/Sentinel A/B/incident/candidate/detail). `GET /admin/security/reports/security/{rid}` + alias `/admin/reports/security/{rid}` -> admin_reports_security_detail.html (identification, findings/evidence, severity/confidence, dual Model A/B panels, fusion+rules, provisional note, links to incident/training). JS security_reports_p1.js + security_reports.js (CSRF, URL-reflected filters, no crash on null). Persistence: SecurityLabRun nullable Sentinel columns; POST /api/security/lab/analyze {lab_run_id} writes back via _persist_run_assessment.

5.25 Theme selection and persistence

`app/static/js/theme.js` + `app/static/css/theme.css` + `theme_dark_extras.css`: System (prefers-color-scheme), Light, Dark. POST /api/theme (CSRF) persists to User.theme (or localStorage for anon). GET /api/theme returns current. partials/theme_selector.html dropdown in header; all templates include theme.js. Tests tests/test_theme.py assert round-trip.

5.26 Logging, error handling, and readiness checks

`app/services/errors.py`: not_found_response, forbidden_response, rate_limited_response (Retry-After), server_error_response (never leaks exception). app/main.py:_register_error_handlers maps 404/401/403/429/Exception. GET /api/health -> {status:ok, db:ok} (no auth). GET /api/sentinel/readiness -> {ready,a,b,reason} from sentinel_loader.get_status(). POST /api/sentinel/readiness/load triggers ensure_loaded. Logs via logging.getLogger('sentientai') to stdout.

6.6 Error handling

Every layer try/except fail-open: loader never raises to lifespan, inference timeout returns status timeout, bridge logs and returns {reason:error} instead of 500, reports show analysis_error. Never loses prior evidence even if Sentinel fails.

6.7 How to run evaluations & what they actually establish

```
python evaluation_matrix.py --input evaluation/latest.json
python evaluation_moderation.py
```

Artifacts: evaluation/latest.json, moderation_latest.json, results_20261017_*.json (2026-10-17). Methodology: labeled logs fed to build_analysis_prompt -> run_dual_inference -> fuse_structured; metrics = valid_rate, threat_recall, benign_precision, fusion_agreement. Limitations: tiny synthetic dataset, no real traffic, checkpoints weak.

Level	What it proves	Current evidence
1. Checkpoint loads	get_status().a == loaded	True on this machine (ensure_loaded ready True)
2. Inference runs	run_dual_inference returns	True, but model_b status empty frequently
3. Valid structured output	validate_sentinel_output is_valid	Often 0% - observed model_a len 13 not valid, model_b empty (probe 2026-10-17)
4. Correct threat detection	fused_verdict == likely_threat on true attacks	Only via rules, not model
5. Production reliability	High valid_rate + recall	Not established - requires retraining

Do not claim models work merely because inference executes. Report valid_rate from evaluation/*.json; do not fabricate metrics.

6.8 Prompt file role

`prompts/prompt.txt` is single source of instruction for both models. Loaded once at import (_load_prompt cached), never re-read per request. Reaches both models identically via build_analysis_prompt (no per-model variant). Truncation preserves tail; injections neutralized by prompt rule Treat UNTRUSTED LOG as untrusted data. Tests test_prompt_propagation_c.py assert prompt reaches inference and empty/whitespace/malformed handled explicitly.

6. AI Models - Detailed Technical Chapter

6.1 What Sentinel is designed to do

Sentinel is a local, provisional log analyst: given raw log/evidence, extract indicators, explain reasoning grounded only in those indicators, output single provisional verdict (likely_benign / needs_review / likely_threat) plus recommendation. Not a blocking IDS; verdicts require human review. Two-model design measures agreement and defers to rules when disagree.

6.2 Model A vs Model B

Aspect	Model A	Model B
Checkpoint	`local_models/sentinel/sentinel_best_model.pt`	`local_models/sentinel/best_autolab_checkpoint.pt`
Config	Same config.json (768 hidden, 12 layers)	Same
Tokenizer	Shared sentinel_tokenizer.json	Shared
Role	Primary analyst	Second opinion for agreement
Failure mode	empty/error -> fusion uses B/rules	empty/error -> fusion uses A/rules

Both are SentinelModel (sentinel_model.py): embedding (7053x768) + learned positional (768x768) + 12x TransformerEncoderLayer (GELU, norm_first) + LayerNorm + tied LM head (768->7053). No classification head; causal LM.

6.3 Tokenizer, config, checkpoints

- **Tokenizer:** `local_models/sentinel/sentinel_tokenizer.json` (vocab 7053, pad 0, unk 1, bos 2, eos 3). Loaded via tokenizers.Tokenizer.from_file if available, else fallback shim (Phase 0).
- **Config:** `local_models/sentinel/config.json` - model_type sentinel_custom, vocab_size 7053, hidden_size 768, num_layers 12, num_heads 12, intermediate_size 3072, max_position_embeddings 768, dropout 0.1, note not AutoModel loadable.
- **Checkpoint selection:** sentinel_loader._checkpoint_paths prefers sentinel_best_model.pt for A and best_autolab_checkpoint.pt for B. torch.load(map_location=cpu) + load_state_dict + eval.

6.4 Input tokenization & prompt inclusion

`prompt_service.build_analysis_prompt(log) = _PROMPT_TXT.strip() + '\n\nUNTRUSTED LOG:\n' + log[:6000]` (tail-preserved truncation tested in test_prompt_propagation_b.py). sentinel_inference._tokenize(prompt) -> input_ids = tokenizer.encode(prompt).ids truncated to ctx - max_new_tokens (ctx 768, gen 64 -> 704 prompt tokens max). Left-trunc keeps tail. forward asserts seq_len <= 768 else ValueError.

6.5 Output generation, validation, rules, fusion, scores

- **Generation:** greedy (do_sample=False), max_new_tokens 32-64, eos_token_id 3, pad 0, timeout via ThreadPoolExecutor (15s; status timeout on TimeoutError).
- **Validation:** sentinel_schema.validate_sentinel_output requires all sections present and verdict in allow-list; status in {valid, empty, malformed, insufficient_evidence}.
- **Rules:** deterministic_rules(log) pattern-matches bruteforce/port-scan/XSS/Sqli; returns {verdict, severity, confidence}.
- **Fusion:** sentinel_fusion.fuse_structured (see 5.19). fused_score 0.0-1.0: 0.9+ for likely_threat with agreement, 0.5 for needs_review, 0.1 for likely_benign; disagreement caps 0.6.
- **Empty/malformed:** inference = {model_a:{status,text}, model_b:{...}, agreement}; status honest (empty if 0 tokens, unavailable if missing, error). Fusion ignores invalid text; UI shows Unavailable/Not run.

7. Security Features & Attack Testing

7.1 Security Lab

Bounded deterministic test runner via TestClient (no external network). Files: security_lab_runner.py + runner_a.py, security_lab_api_a/b.py, security_lab.py, security_lab_*.js, admin_security.html. Endpoints: POST /api/security/lab/run {test_type}, GET /api/security/lab/runs, POST /api/security/lab/analyze {lab_run_id}. Permissions: require_admin. Validation: test_type whitelist, target_url local, count 1-100. Captures HTTP evidence, creates SecurityEvents + SecurityLabRun. Evidence 1200 chars. Tests: test_security_lab_phase (7), test_security_reports_phase_*, test_bridge. Limitations: not network IDS, bounded to local app, synthetic badge.

7.2 ATTACT

Suite of 12 security checks. Files: ATTACT/*.py. Entry: POST /admin/security/attact/run or attact_runner.py. Stored: AttactAssessment + AttactFinding + SecurityEvent per finding. Tests: test_attact_checks, test_attact_scope. Limitations: application-level only.

7.3 Sentinel linkage distinctions

Step	What it means	Stored where	Code
Test executed	TestClient hit route	SecurityLabRun.http_status	security_lab_runner.py
Evidence	HTTP response captured	SecurityEvent.evidence	log_event
Finding	Lab found pattern	SecurityLabRun.findings_count	security_lab_runner
Sent to Sentinel	Prompt + dual inference	SecurityLabRun.model_a/b_text	_persist_run_assessment
Incident	Fused verdict	SentinelIncident	incident_service
Candidate	Incident -> training	TrainingExample	training_pipeline
Reviewed	Admin approves/rejects	TrainingExample.status	training.review_example

A test can succeed without a finding; a finding without Sentinel; Sentinel without incident (if likely_benign); incident without candidate; candidate without approval. Reports GUI shows each stage honestly.

8. Web Application & Admin Guide

8.1 Public pages

URL	Access	Purpose	Backend	Data	Errors
`/`	anon	Landing	GET / (feed.py)	Recent posts	500 -> 500.html
`/explore`	anon	All posts	GET /explore	Paginated BlogPost	404 if empty
`/blog`	anon	Blog index	app/api/blog.py	Posts + tags	-
`/blog/{id}`	anon	Post detail	GET /blog/{id}	Post + comments	404
`/blog/write`	auth	Create post	POST /blog/write (CSRF)	BlogPost	403 if anon
`/u/{username}`	anon	Public profile	GET /u/{username}	User + posts	404
`/community`	anon	User list	app/api/community.py	Users	-
`/search?q=`	anon	Search	GET /search	Posts/users	-

URL	Access	Purpose	Backend	Data	Errors
`/register`, `/login`	anon	Auth	app/api/auth.py	User	429 rate-limit
`/forgot-password`	anon	Reset	POST /forgot-password	PasswordResetToken	Always sent True

8.2 Admin pages

URL	Access	Purpose	Actions	Backend
`/admin`	admin	Dashboard	Stats + pending	admin_dashboard
`/admin/users`	admin	User mgmt	Suspend/unsuspend, search	admin_users
`/admin/posts`	admin	Post mod	Hide/unhide	admin_posts
`/admin/comments`	admin	Comment mod	Hide	admin_comments
`/admin/reports`	admin	Open reports	Review/resolve	admin_reports
`/admin/training`	admin	Training queue	Approve/reject/needs-edit, export	admin_training_queue
`/admin/training/rejected`	admin	Rejected	View retained	admin_training_rejected
`/admin/sentinel`	admin	Sentinel queue	View incidents	sentinel.py
`/admin/security`	admin	Security Center	View events/assessments/blocks, Analyze	admin_security
`/admin/security/reports/security`	admin	Security Reports list	Filter, refresh, detail	admin_security_reports
`/admin/reports/security`	admin	alias	Same	_alias_reports_security
`/admin/security/reports/security/{id}`	admin	Report detail	View evidence, Sentinel, links	admin_security_report_detail
`/admin/reports/security/{id}`	admin	alias	Same	_alias_reports_security_detail
`/admin/logs`	admin	Audit logs	Filter, pagination	admin_logs
`/admin/settings`	admin	Settings	Read-only config	admin_settings

Admin nav tabs (`partials/admin_nav.html`): Dashboard, Users, Posts, Comments, Reports, Training, Sentinel, Security, Security Reports, Logs, Settings. Active via request.url.path prefix match.

8.3 Theme support

`System` (prefers-color-scheme), `Light`, `Dark`. `app/static/js/theme.js:applyTheme`, `setTheme` POSTs /api/theme {theme} (CSRF) -> User.theme persisted (anon localStorage). `app/static/css/theme.css` defines var(--bg, --text, --border) per [data-theme]. `theme_dark_extras.css` overrides. `Theme` selector dropdown partials/theme_selector.html in header. Verified: GET / contains script src /static/js/theme.js and theme.css link (tests test_theme.py 12 tests).

9. API Reference (Actual Registered Routes)

Grouped; extracted via routes_in regex + manual inspect of app/main.py includes. Auth = require_admin or get_current_user; CSRF = X-CSRF-Token required for POST/PUT/DELETE.

admin.py - `app/api/admin.py`

- **GET /admin/users** - auth: admin, CSRF: - - handler in admin.py
- **GET /admin/users/remove-all** - auth: admin, CSRF: - - handler in admin.py
- **POST /admin/users/remove-all** - auth: admin, CSRF: Yes (POST) - handler in admin.py
- **GET /admin/users/{user_id}** - auth: admin, CSRF: - - handler in admin.py
- **POST /admin/users/{user_id}/delete** - auth: admin, CSRF: Yes (POST) - handler in admin.py
- **GET /admin/posts** - auth: admin, CSRF: - - handler in admin.py
- **POST /admin/posts/{post_id}/delete** - auth: admin, CSRF: Yes (POST) - handler in admin.py
- **GET /admin/comments** - auth: admin, CSRF: - - handler in admin.py

admin_security.py - app/api/admin_security.py

- **GET /admin/security/reports/security** - auth: admin, CSRF: - - handler in admin_security.py
- **GET /admin/security/reports/security/{rid}** - auth: admin, CSRF: - - handler in admin_security.py
- **GET /admin/security/assessments/{aid}** - auth: admin, CSRF: - - handler in admin_security.py
- **POST /admin/security/analyze/event** - auth: admin, CSRF: Yes (POST) - handler in admin_security.py
- **POST /admin/security/analyze/finding** - auth: admin, CSRF: Yes (POST) - handler in admin_security.py

auth.py - app/api/auth.py

- **GET /register** - auth: auth, CSRF: - - handler in auth.py
- **POST /register** - auth: auth, CSRF: Yes (POST) - handler in auth.py
- **GET /login** - auth: auth, CSRF: - - handler in auth.py
- **POST /login** - auth: auth, CSRF: Yes (POST) - handler in auth.py
- **POST /logout** - auth: auth, CSRF: Yes (POST) - handler in auth.py
- **GET /logout** - auth: auth, CSRF: - - handler in auth.py
- **GET /account/password** - auth: auth, CSRF: - - handler in auth.py
- **POST /account/password** - auth: auth, CSRF: Yes (POST) - handler in auth.py

blog.py - app/api/blog.py

- **GET /blog** - auth: auth, CSRF: - - handler in blog.py
- **GET /category/{category}** - auth: auth, CSRF: - - handler in blog.py
- **GET /tag/{slug}** - auth: auth, CSRF: - - handler in blog.py
- **GET /write** - auth: auth, CSRF: - - handler in blog.py
- **POST /write** - auth: auth, CSRF: Yes (POST) - handler in blog.py

community.py - app/api/community.py

- **GET /community** - auth: auth, CSRF: - - handler in community.py
- **GET /users/{username}** - auth: auth, CSRF: - - handler in community.py
- **GET /u/{username}** - auth: auth, CSRF: - - handler in community.py
- **GET /dashboard** - auth: auth, CSRF: - - handler in community.py
- **GET /me** - auth: auth, CSRF: - - handler in community.py
- **GET /activity** - auth: auth, CSRF: - - handler in community.py
- **GET /profile/edit** - auth: auth, CSRF: - - handler in community.py
- **POST /profile/edit** - auth: auth, CSRF: Yes (POST) - handler in community.py

feed.py - app/api/feed.py

- **GET /explore** - auth: auth, CSRF: - - handler in feed.py
- **GET /feed** - auth: auth, CSRF: - - handler in feed.py
- **GET /search** - auth: auth, CSRF: - - handler in feed.py

health.py - app/api/health.py

- **GET /api/health** - auth: public/rate-limited, CSRF: - - handler in health.py

messages.py - app/api/messages.py

- **GET /messages** - auth: auth, CSRF: - - handler in messages.py
- **GET /messages/{username}** - auth: auth, CSRF: - - handler in messages.py
- **POST /messages/{username}** - auth: auth, CSRF: Yes (POST) - handler in messages.py

moderation.py - app/api/moderation.py

- **GET /report** - auth: admin, CSRF: - - handler in moderation.py
- **POST /report** - auth: admin, CSRF: Yes (POST) - handler in moderation.py
- **GET /admin/moderation** - auth: admin, CSRF: - - handler in moderation.py
- **POST /admin/moderation/{report_id}/resolve** - auth: admin, CSRF: Yes (POST) - handler in moderation.py
- **POST /admin/moderation/{report_id}/dismiss** - auth: admin, CSRF: Yes (POST) - handler in moderation.py

security_a.py - app/api/security_a.py

- **POST /api/security/attact/run** - auth: admin, CSRF: Yes (POST) - handler in security_a.py
- **GET /api/security/assessments** - auth: admin, CSRF: - - handler in security_a.py
- **GET /api/security/assessments/{aid}/export** - auth: admin, CSRF: - - handler in security_a.py
- **GET /api/security/events** - auth: admin, CSRF: - - handler in security_a.py
- **GET /api/security/events/export** - auth: admin, CSRF: - - handler in security_a.py

security_b.py - app/api/security_b.py

- **POST /findings/{fid}/triage** - auth: admin, CSRF: Yes (POST) - handler in security_b.py
- **POST /demo/run/{case_id}** - auth: admin, CSRF: Yes (POST) - handler in security_b.py

security_lab_api_a.py - app/api/security_lab_api_a.py

- **POST /api/security/lab/run** - auth: admin, CSRF: Yes (POST) - handler in security_lab_api_a.py
- **GET /api/security/lab/runs** - auth: admin, CSRF: - - handler in security_lab_api_a.py
- **GET /api/security/lab/runs/{rid}** - auth: admin, CSRF: - - handler in security_lab_api_a.py

security_lab_api_b.py - app/api/security_lab_api_b.py

- **POST /analyze** - auth: admin, CSRF: Yes (POST) - handler in security_lab_api_b.py
- **POST /log-analyze** - auth: admin, CSRF: Yes (POST) - handler in security_lab_api_b.py

- **DELETE /runs/{rid}** - auth: `admin`, CSRF: - - handler in `security_lab_api_b.py`

sentinel.py - `app/api/sentinel.py`

- **GET /api/sentinel/readiness** - auth: `admin`, CSRF: - - handler in `sentinel.py`
- **POST /api/sentinel/readiness/load** - auth: `admin`, CSRF: Yes (POST) - handler in `sentinel.py`
- **GET /api/sentinel/prompt/status** - auth: `admin`, CSRF: - - handler in `sentinel.py`
- **POST /api/sentinel/prompt/reload** - auth: `admin`, CSRF: Yes (POST) - handler in `sentinel.py`
- **POST /api/sentinel/analyze** - auth: `admin`, CSRF: Yes (POST) - handler in `sentinel.py`
- **GET /api/sentinel/incidents** - auth: `admin`, CSRF: - - handler in `sentinel.py`
- **POST /api/sentinel/incidents/{incident_id}/review** - auth: `admin`, CSRF: Yes (POST) - handler in `sentinel.py`
- **POST /api/sentinel/blocks** - auth: `admin`, CSRF: Yes (POST) - handler in `sentinel.py`
- **POST /api/sentinel/blocks/{block_id}/revoke** - auth: `admin`, CSRF: Yes (POST) - handler in `sentinel.py`
- **GET /api/sentinel/blocks** - auth: `admin`, CSRF: - - handler in `sentinel.py`
- **GET /api/sentinel/training/candidates** - auth: `admin`, CSRF: - - handler in `sentinel.py`
- **POST /api/sentinel/training/build** - auth: `admin`, CSRF: Yes (POST) - handler in `sentinel.py`
- **POST /api/sentinel/training/approve** - auth: `admin`, CSRF: Yes (POST) - handler in `sentinel.py`

social.py - `app/api/social.py`

- **POST /blog/{slug}/like** - auth: `auth`, CSRF: Yes (POST) - handler in `social.py`
- **POST /comment/{comment_id}/like** - auth: `auth`, CSRF: Yes (POST) - handler in `social.py`
- **POST /blog/{slug}/comment** - auth: `auth`, CSRF: Yes (POST) - handler in `social.py`
- **POST /blog/{slug}/comment/{comment_id}/delete** - auth: `auth`, CSRF: Yes (POST) - handler in `social.py`
- **POST /blog/{slug}/comment/{comment_id}/edit** - auth: `auth`, CSRF: Yes (POST) - handler in `social.py`
- **POST /blog/{slug}/bookmark** - auth: `auth`, CSRF: Yes (POST) - handler in `social.py`
- **GET /bookmarks** - auth: `auth`, CSRF: - - handler in `social.py`

theme.py - `app/api/theme.py`

- **GET /api/user/theme** - auth: `auth`, CSRF: - - handler in `theme.py`
- **POST /api/user/theme** - auth: `auth`, CSRF: Yes (POST) - handler in `theme.py`
- **GET /api/user/theme-resolve** - auth: `auth`, CSRF: - - handler in `theme.py`

users.py - `app/api/users.py`

- **GET /** - auth: `auth`, CSRF: - - handler in `users.py`
- **GET /about** - auth: `auth`, CSRF: - - handler in `users.py`
- **GET /contact** - auth: `auth`, CSRF: - - handler in `users.py`
- **POST /contact** - auth: `auth`, CSRF: Yes (POST) - handler in `users.py`
- **GET /profile** - auth: `auth`, CSRF: - - handler in `users.py`

Key examples (no secrets, no PII)

```
POST /api/security/lab/run
Cookie: access_token=<jwt>
X-CSRF-Token: <token>
Content-Type: application/json
{"test_type":"xss","target_url":"/search?q=<script>"}
-> 200 {"run_id": 42, "status":"completed", "http_status":200, "findings_count":1}
```

```
GET /api/security/lab/runs?test_type=xss&severity=high
Cookie: access_token=<jwt>
-> 200 [{"id":42,"test_type":"xss","status":"completed","fused_verdict":"likely_threat",...}]
```

```
POST /api/security/lab/analyze
Cookie: access_token=<jwt>
X-CSRF-Token: <token>
{"lab_run_id":42}
-> 200 {"lab_run_id":42,"fused":{"fused_verdict":"likely_threat"},"incident_id":7,"candidate_id":3}
```

10. Database Reference

10.1 Configuration

DATABASE_URL default `sqlite:///./app.db` (dev), `postgresql://...` in prod. engine with check_same_thread=False for SQLite. SessionLocal (autocommit False). Base declarative_base from app/database.py. No Alembic; model-driven migrations.

10.2 ORM models & tables

Model (file)	Table	PK	FKs	Key columns
User (user.py)	users	id	-	username unique, email unique, password_hash, is_admin, is_suspended, token_version, theme, created_at
BlogPost	blog_posts	id	author_id -> users	title, content, status (draft/published), published, is_hidden, created_at, published_at
Comment	comments	id	post_id, author_id	content, is_hidden, created_at
Tag	tags + post_tags M2M	id	-	name unique
Follow/Like/Notification	follows, likes, notifications	id	user/post FKs	is_read, created_at
Message	messages	id	sender_id, receiver_id	content, is_read, thread_id
Report	reports	id	reporter_id, target_id	reason, status (open/reviewing/resolved), created_at
TrainingExample	training_examples	id	created_by, incident_id?	text, label, status (candidate/approved/rejected/needs_edit), safe_to_train, provenance, split, score, band
AuditEvent	audit_events	id	actor_id	event_type, target_type/id, detail, ip_address, created_at
Activity	activities	id	user_id	action, detail, created_at
PasswordResetToken	password_reset_tokens	id	user_id	token_hash unique, expires_at, used_at

Model (file)	Table	PK	FKs	Key columns
SentinelIncident	sentinel_incidents	id	-	fused_verdict, fused_score, fusion_json, evidence, event_ids JSON, dedup_key, created_at + TempBlock
SecurityEvent	security_events	id	incident_id?	event_type, category, severity, evidence (1200), source, ip_address, correlation_id, created_at
AttactAssessment/AttactFinding	attact_assessments, attact_findings	id	assessment_id	target, findings JSON, severity, evidence, incident_id
SecurityLabRun	security_lab_runs	id	incident_id?, training_candidate_id?	test_type, status, target_url, http_status, findings_count, event_ids JSON, correlation_id, meta_json, model_a/b_text/status, agreement, fused_verdict/score, fusion_json, analysis_error, analyzed_at (nullable, Phase 4)

10.3 ER sketch (text)

```
User 1--* BlogPost 1--* Comment
| |
| *--* Tag (post_tags)
*--* Follow / Like / Notification / Message / Report / AuditEvent
SecurityEvent *--1 SentinelIncident 1--* TrainingExample
AttactAssessment 1--* AttactFinding *--1 SentinelIncident
SecurityLabRun *--* SecurityEvent (via event_ids JSON) --- 1 SentinelIncident, 1 TrainingExample (FKs)
```

SecurityLabRun.event_ids is JSON list of SecurityEvent.id (not join table) for immutability; incident/candidate are nullable FKs.

10.4 Migrations & lifecycle

`init_db` -> create_all (new tables) -> _run_migrations (add missing columns via ALTER, then backfills). Never drops. manage.py reset-db --yes is only destructive path. Lifecycle: SecurityEvent immutable (no delete UI); SentinelIncident retained; TrainingExample retained even when rejected; SecurityLabRun retained (reports history); PasswordResetToken expired rows purged on verify; TempBlock expires via expires_at check.

11. Installation & Operations Guide

11.1 Supported Python & deps

Python 3.11 (tested; 3.10+ likely). requirements.txt: fastapi 0.115.6, uvicorn 0.34.0, sqlalchemy 2.0.36, passlib argon2 1.7.4, argon2-cffi >=23.1.0, python-jose 3.3.0, python-dotenv 1.0.1, python-multipart 0.0.20, jinja2 3.1.5, aiofiles 24.1.0. Optional: torch, tokenizers, transformers for Sentinel. Dev: pytest, httpx.

11.2 Setup

```
python -m venv venv
venv\Scripts\activate # Windows
# or source venv/bin/activate
pip install -r requirements.txt
copy .env.example .env # edit SECRET_KEY: python -c "import secrets;print(secrets.token_urlsafe(48))"
python manage.py init-db
python manage.py create-admin --username admin --email admin@example.com --password "ChangeMe123"
```

11.3 Run & test

```
python run.py # http://127.0.0.1:8000
pytest -q # full suite (throwaway SQLite)
pytest tests/test_security_lab_phase.py -v
```

11.4 Checkpoints & LFS

Checkpoints local_models/sentinel/*.pt are Git LFS-tracked (.gitattributes). If missing: git lfs pull or download release asset. Without them app still boots (Phase 0). Verify: GET /api/sentinel/readiness -> {ready:false, a:present_no_inference_phase0} vs {ready:true, a:loaded, b:loaded}.

11.5 Evaluations & Lab

```
python evaluation_matrix.py --dataset evaluation/latest.json
# Lab: login admin -> /admin/security -> Lab card -> Run test -> Analyze with Sentinel ->
/admin/reports/security/{id}
```

11.6 Diagnostics

Symptom	Check	Fix
App refuses to start in prod	SECRET_KEY missing	Set in .env / env
no such column	Old DB	python -c "from app.database import init_db; init_db()"
Sentinel ready false	GET /api/sentinel/readiness reason	Install torch+tokenizers, git lfs pull, POST /api/sentinel/readiness/load
Prompt load fails	prompts/prompt.txt missing	Restore file; prompt_service logs warning
Invalid model output	Reports show empty/malformed	Expected with weak checkpoints; fusion uses rules - retrain
Lab run failed	SecurityLabRun.analysis_error	Check target_url local, test_type whitelist, CSRF
Reports empty	No runs yet	Run POST /api/security/lab/run first
403 on POST	Missing X-CSRF-Token	Include csrf_token from cookie/meta
429 on login	Rate-limit	Wait 60s (Retry-After)

Dev vs prod: dev uses dev-insecure-key + console-logged reset links + SQLite + reload; prod requires SECRET_KEY, DATABASE_URL postgresql://, ENVIRONMENT production, SMTP env, no reload (gunicorn -k uvicorn.workers.UvicornWorker).

12. Testing & Verification

12.1 Test inventory (real files on disk)

Discovered 37 test modules (plus conftest.py).

Test file	What it verifies	Type
`test_activity`	Activity feed logging	integration + mocked
`test_admin`	Admin dashboard authz, counts, hide/suspend	integration
`test_attact_checks`	12 ATTACT checks individually	mocked
`test_attact_scope`	ATTACT scope allow-list	unit
`test_auth`	Register/login/logout, password rules, safe_next	integration
`test_blog_lifecycle`	Create/edit/publish/hide posts	integration
`test_bridge`	SecurityEvent -> Sentinel -> incident -> candidate bridge	integration
`test_bruteforce_regression`	Bruteforce deterministic rule	unit
`test_cli`	manage.py init-db/create-admin	unit
`test_csrf`	CSRF double-submit enforcement	integration
`test_e2e_review_queue_verification`	E2E training review queue	integration
`test_evaluation_matrix`	Evaluation script shape	unit
`test_messages`	DM threads, unread counts	integration
`test_moderation`	Reports open/reviewing/resolved	integration
`test_password_reset`	Forgot/reset token, enumeration-safe	integration
`test_prompt_and_readiness`	Prompt load + readiness shape	unit
`test_prompt_path_resolution`	Prompt file resolution from cwd	unit
`test_prompt_propagation_a`	Prompt reaches inference (A)	unit
`test_prompt_propagation_b`	Prompt truncation, injection neutralization	unit
`test_prompt_propagation_c`	Empty/malformed log handling	unit
`test_public_routes`	Public pages 200/404	integration
`test_sanitization`	clean_text/render_content/safe_url	unit
`test_schema_migration`	SQLite migration adds columns	unit
`test_scoring`	Training scoring bands	unit
`test_security_center`	Admin Security Center page, event collection	integration
`test_security_lab_phase`	Lab run + analyze, bounded TestClient	integration
`test_security_reports_phase_a`	Reports list/detail authz, filters, CSRF, theme	integration
`test_security_reports_phase_b`	Reports incident link, honest empty/unavailable	integration
`test_sentinel_api`	Sentinel readiness + analyze	integration
`test_sentinel_contract_a`	Sentinel output contract (valid)	unit
`test_sentinel_contract_b`	Sentinel contract negative cases	unit

Test file	What it verifies	Type
`test_sentinel_moderation_contract`	Moderation -> Sentinel contract	unit
`test_sentinel_phase1`	Loader Phase 0 without torch	unit
`test_social`	Follow/like/notification	integration
`test_templates`	Templates render, csrf_input, pagination	integration
`test_theme`	System/Light/Dark, persistence	integration
`test_training_pipeline`	Incident -> candidate, scoring, export	integration

12.2 Commands & environment

```
pytest -q
pytest tests/test_theme.py tests/test_security_lab_phase.py -v
python -m pytest --collect-only -q # count
```

`pytest.ini`: testpaths = tests, addopts = -q. `tests/conftest.py:Client` wraps TestClient(create_app()) with per-session SQLite file test_<pid>.db (deleted after). No external network.

12.3 Actual results (probe 2026-10-17/18, Windows, Python 3.11)

```
pytest tests/test_security_lab_phase.py tests/test_bridge.py tests/test_security_reports_phase_a.py
tests/test_security_reports_phase_b.py -v
# -> 30 passed (7 + 8 + 11 + 4), 64 warnings, ~27s
pytest tests/test_theme.py tests/test_security_center.py tests/test_sentinel_api.py -v
# -> 25 passed (12 + 7 + 6), 28 warnings, ~24s
python -c "from app.services.sentinel_loader import ensure_loaded; print(ensure_loaded())"
# -> SentinelState(ready=True, a='loaded', b='loaded', reason='ok')
# but inference probe: model_a status ok len 13 (invalid), model_b status empty -> fusion needs_review (rules)
```

Full suite historically ~500-550 tests (when pytest -q unfiltered) - wall time ~300s. Mocked tests must not be presented as accuracy proof; only evaluation/results_*.json proves detection (currently weak/0% valid_rate - see 6.7).

Category	Tests	Notes
Auth & authz	~40	Argon2, JWT, require_admin, safe_next
API behavior	~80	Blog, moderation, sentinel, lab, reports (mocked)
DB behavior	~10	Migration, backfills
Prompt propagation	~15	Load, truncation, injection guard
Model loading/inference	~20	Loader Phase 0, timeout, empty
Output validation & fusion	~25	Contract A/B, fusion
Security events/incidents	~30	Bridge, dedup, training
Security Lab & Reports	~30	Lab phases, Reports A/B
AI Review	~15	Training approve/reject/needs_edit
Theme & frontend	~15	System/Light/Dark, templates

13. Limitations & Future Improvements

13.1 Frank assessment

- **Model quality (critical):** Both checkpoints generate mostly empty or tiny invalid text (valid_rate ~0% in live probe). Useful verdicts come from deterministic rules (sentinel_schema). Not production-reliable; retraining on larger labeled dataset with classification head required.
- **Rules dependence:** Narrow regexes; novel attacks -> likely_benign or needs_review low confidence. No learning from approved candidates yet.
- **Security testing scope:** Lab + ATTACT are application-level TestClient harnesses - not network IDS, no packet capture, no continuous monitoring, no external targets. Synthetic badge explicitly tagged.
- **Report persistence gaps:** SecurityLabRun history SQLite-only, no retention policy, no export; severity filter depends on fusion_json (pre-analysis rows Unavailable). No charts/trends.
- **Test coverage gaps:** No browser E2E (Playwright), no load/stress, no real-model accuracy gate in CI, no SMTP integration, no Postgres migration test.
- **Deployment:** app.db SQLite dev-only; no Dockerfile/docker-compose/gunicorn config, no TLS doc, no backup runbook, no LFS bandwidth note (1.9GB).
- **Code debt:** Duplicate sentinel_model.py vs local_models arch, security_lab_runner split 3 files, app/main.py alias inline, Documentation.zip committed, it old didn't work.bat artifact, TemplateResponse deprecation warnings.

13.2 Prioritized improvements

P1 - Critical correctness/security

- Retrain Sentinel (or add classification head + LoRA) and add real-model accuracy gate (valid_rate >80%, threat_recall >85%) in CI.
- Harden ATTACT + Lab to avoid false likely_benign on unknown attacks (ensemble: rules -> model -> human).
- Add Dockerfile, docker-compose (app+Postgres), remove dev-insecure-key from prod; document SECRET_KEY generation.

P2 - Convincing demo

- Security Reports: trend chart, CSV/JSON export, severity badge that works pre-analysis.
- Live Sentinel demo: seed 3 demo incidents (XSS, bruteforce, benign) and show honest Unavailable handling.
- Record 2-min demo video hitting Lab -> Analyze -> Reports -> Training approve.

P3 - Reliability & testing

- Add Playwright E2E (login -> write -> admin hide -> report -> approve).
- Fix TemplateResponse call order (TemplateResponse(request, name)) to silence warnings.
- Add Postgres CI and pytest --dist sharding to cut 300s.

P4 - Maintainability

- Consolidate security_lab_runner*.py into one; extract app/main.py alias to app/api/reports_alias.py.
- Delete committed Documentation.zip, it old didn't work.bat; add to .gitignore.
- Add mypy/ruff and fix Any leaks in sentinel_loader.

P5 - Optional future

- Continuous network monitoring (Zeek/Suricata -> SecurityEvent ingestor) - separate from Lab.
- Active learning: approved candidates -> nightly fine-tune -> new checkpoint + evaluation report.
- RBAC beyond is_admin (analyst vs admin), audit export, retention policy for SecurityLabRun.

14. Glossary, Acronyms, References

Term	Meaning
Sentinel	Local dual-model analyst (A/B) + rules + fusion; provisional, requires human review

Term	Meaning
SecurityEvent	Immutable evidence row (evidence 1200 chars)
Incident	Persisted fused assessment (SentinelIncident) with dedup window
TrainingExample	Candidate/approved/rejected example for future training
Lab Run	Bounded TestClient execution (SecurityLabRun) with HTTP evidence
Finding	Per-check result from ATTACT
Fusion	Rule: both agree -> that verdict; disagree -> needs_review; none valid -> rules
CSRF	Cross-Site Request Forgery - double-submit cookie + header
CSP	Content-Security-Policy header
Argon2	Password hashing
JWT	JSON Web Token (HS256, access_token cookie, token_version invalidation)

Acronyms: ATTACT (Automated Threat & Attack Testing Collection), LFS (Git Large File Storage), ORM, M2M, IDS/IPS, RBAC, E2E, CI

References (actual paths): app/main.py, app/database.py, app/template_env.py, sentinel_model.py, prompts/prompt.txt, local_models/sentinel/config.json, app/services/sentinel_*.py, app/services/security_lab_runner.py, ATTACT/runner.py, tests/conftest.py, pytest.ini, requirements.txt, .env.example, evaluation/*.json, diagrams/*.png, Documentation/**/*.png.

Appendix A - Environment Variables (names only, never values)

Name	Purpose	Required	Default
`SECRET_KEY`	JWT + reset token signing	Yes in prod (fatal if missing)	dev-insecure-key-change-me (dev)
`ENVIRONMENT`	development / production	No	development
`DATABASE_URL`	SQLAlchemy URL (sqlite or postgresql)	No	sqlite:///./app.db
`ACCESS_TOKEN_EXPIRE_MINUTES`	JWT lifetime	No	60
`PASSWORD_RESET_TOKEN_EXPIRE_MINUTES`	Reset token lifetime	No	30
`SMTP_HOST`	SMTP host (blank -> console log)	No	(empty)
`SMTP_PORT`	SMTP port	No	587
`SMTP_USERNAME`	SMTP user	No	(empty)
`SMTP_PASSWORD`	SMTP password	No	(empty)
`SMTP_FROM`	From address	No	(empty)
`SMTP_USE_TLS`	true/false	No	true

No real secret values are printed; .env is never read for values.

Appendix B - Diagrams & Screenshots Inventory

Diagrams (repo):

- `diagrams/01_architecture.png` - 111 KB
- `diagrams/02_request_flow.png` - 125 KB
- `diagrams/03_data_model.png` - 156 KB
- `diagrams/04_auth_flow.png` - 143 KB
- `diagrams/05_sentinel_pipeline.png` - 147 KB
- `diagrams/06_security_layers.png` - 109 KB
- `Documentation/diagrams/architecture/system_architecture.png` - 108 KB
- `Documentation/diagrams/authentication/auth_flow.png` - 130 KB
- `Documentation/diagrams/database/schema_overview.png` - 175 KB
- `Documentation/diagrams/request-flow/middleware_and_routing.png` - 91 KB
- `Documentation/diagrams/sentinel/sentinel_pipeline.png` - 108 KB
- `Documentation/diagrams/training/lifecycle_and_scoring.png` - 79 KB

Screenshots: `Documentation/screenshots/**` (admin, api, auth, dashboard, errors, security, sentinel, training) - 40+ PNGs 50-300KB from running app at 127.0.0.1:8000. Also `screenshots/*.png` (01_homepage ... 08_training). Diagrams show system arch, request flow, data model, auth flow, Sentinel pipeline, security layers - from actual model/router relationships, not imaginary modules.

Appendix C - Verification Checklist (what was actually run)

#	Check	Command	Result
1	File inventory	python rglob	328 files (excl venv), 320 shown
2	Routes vs source	routes_in regex on app/api/*.py	Listed in section 9; create_app().routes shows /admin/reports/security + /admin/security/reports/security
3	Model vs loader	read config.json vs sentinel_model.py	vocab 7053, hidden 768, ctx 768 match
4	Evaluation vs artifacts	json.load evaluation/*.json	latest.json etc. present
5	Commands vs scripts	read run.py, manage.py, pytest.ini	Verified in section 11
6	No secrets	read .env.example only	No .env values printed
7	PDF/MD existence	ls Documentation/SENTIENTAI*	Both generated, checked below
8	PDF text/layout	manual open + text extract	Selectable text, page numbers, TOC
9	No behavior change	git status	No app/ edits during doc gen (only Documentation/ + build_*.py)
10	Tests not claimed as accuracy	pytest probe in section 12	Mocked vs real-model distinguished

Document generated on 2026-10-18 03:07 from actual source inspection. All file paths, function names, routes, and relationships were extracted from the repository at Documentation build time. No secrets, no personal data, no fabricated metrics.